

HIPAA

1. Overview

HIPAA (the Health Insurance Portability and Accountability Act) is a **U.S. federal law**, enacted in 1996, that governs the privacy and security of health information. Its security-relevant provisions are primarily found in two major regulatory components: the **Privacy Rule** and the **Security Rule**, later strengthened by the **HITECH Act (2009)** and the **Omnibus Rule (2013)**, which extended direct liability to business associates and increased penalty structures.

Property	Detail
Type	Legal/regulatory — U.S. federal law
Jurisdiction	United States
Enacted	1996 (Security Rule finalized 2003, HITECH 2009, Omnibus Rule 2013)
Protects	Protected Health Information (PHI)
Who must comply	Covered Entities and Business Associates

2. Who Must Comply

- **Covered Entities** — healthcare providers (hospitals, clinics, physicians), health plans (insurers), and healthcare clearinghouses that transmit health information electronically.
- **Business Associates** — any third party that creates, receives, maintains, or transmits PHI on behalf of a covered entity (e.g., cloud hosting providers, billing services, IT vendors, SaaS platforms serving healthcare clients). Since the Omnibus Rule, business associates carry **direct legal liability** under HIPAA, not merely contractual liability to the covered entity.

3. What HIPAA Protects — PHI

Protected Health Information (PHI) is any individually identifiable health information — this includes not just medical records, but any of 18 specific identifiers (name, address, dates, phone numbers, Social Security numbers,

medical record numbers, biometric identifiers, photographs, and more) when combined with health-related information. **Electronic PHI (ePHI)** is PHI in electronic form and is the specific focus of the Security Rule.

4. The Privacy Rule

Governs the use and disclosure of PHI — establishing patients' rights over their own health information and restricting how covered entities and business associates may use or share it.

Key provisions:

- Patients have the right to access, review, and request corrections to their own health records.
- PHI may only be used or disclosed for permitted purposes (treatment, payment, healthcare operations) or with explicit patient authorization, subject to specific exceptions.
- The **"minimum necessary" standard** — PHI use and disclosure should be limited to the minimum necessary to accomplish the intended purpose.

5. The Security Rule

Establishes specific safeguards required to protect **ePHI** — this is the component most directly relevant to security/IT practice, organized into three categories of required and addressable safeguards.

Safeguard Category	Examples
Administrative Safeguards	Risk analysis and management, workforce training, access management procedures, designated security officer, contingency planning
Physical Safeguards	Facility access controls, workstation security, device and media controls (secure disposal of hardware containing ePHI)
Technical Safeguards	Access control (unique user identification, automatic logoff), audit controls/logging, integrity controls, transmission security (encryption in transit)

"Required" vs. "Addressable" specifications: the Security Rule distinguishes between specifications that are strictly mandatory ("required") and those that are "addressable" — meaning the covered entity must assess whether the specification is reasonable and appropriate for their environment, and if not

implementing it as specified, must document an equivalent alternative measure or a justified reason it isn't applicable. "Addressable" does **not** mean optional.

6. Breach Notification Rule

Requires covered entities and business associates to notify affected individuals, the Department of Health and Human Services (HHS), and in some cases the media, following discovery of a breach of unsecured PHI — with specific timelines and content requirements depending on the scale of the breach (e.g., breaches affecting 500+ individuals require more immediate and public notification).

7. Enforcement and Penalties

Enforced primarily by the **HHS Office for Civil Rights (OCR)**. Penalty tiers scale with the level of culpability:

Tier	Culpability	Penalty Range (per violation)
Tier 1	Unknowing violation	Lower range
Tier 2	Reasonable cause	Moderate range
Tier 3	Willful neglect, corrected	Higher range
Tier 4	Willful neglect, not corrected	Highest range, with annual caps

Beyond civil penalties, willful violations can carry **criminal liability**, and organizations frequently face additional costs from breach notification, remediation, litigation, and reputational damage well beyond the formal fine itself.

8. Business Associate Agreements (BAAs)

A covered entity must have a signed **Business Associate Agreement** with any vendor handling PHI on its behalf, contractually obligating the business associate to appropriately safeguard the PHI and outlining permitted uses, breach notification obligations, and liability terms. A BAA is a compliance necessity but, per the Compliance vs. Security guide's core theme, does not by itself guarantee the business associate's actual technical security is adequate.

9. Common Real-World Compliance Gaps

- Incomplete or outdated risk analyses (a required, foundational Security Rule activity often treated as a one-time exercise rather than an ongoing process).
- Business associates handling ePHI without a properly executed BAA.
- Weak or absent encryption for ePHI at rest and in transit (encryption itself is technically "addressable," but its absence is a frequent root cause in breach investigations and a difficult position to defend as a reasonable alternative).
- Inadequate workforce training and access management, leading to excessive or stale access privileges.
- Insufficient audit logging, hampering breach investigation and required notification timelines.

10. Summary

HIPAA is a legally mandated U.S. framework specifically protecting health information, structured around the Privacy Rule (governing use/disclosure of PHI) and the Security Rule (mandating administrative, physical, and technical safeguards for ePHI), backed by mandatory breach notification and tiered civil/criminal penalties. Its "required vs. addressable" safeguard structure is frequently misunderstood — addressable specifications still demand a documented, reasoned decision, not simple omission — and its extension of direct liability to business associates makes vendor security posture a first-class compliance concern, not merely a contractual afterthought.